

Security Assessment Report

Target URL: <http://127.0.0.1:8081/>

Scan ID	#2	Execution Date	2026-09-17T12:09:41.088283
Audit Status	COMPLETED	HTTP Status Code	200

Executive Severity Breakdown

CRITICAL	HIGH	MEDIUM	LOW	INFO
0	2	2	2	2

Section 2: Perimeter Reconnaissance & Asset Intelligence

Passive, non-intrusive attack surface mapping gathered during scan execution. Data sources: Certificate Transparency logs (crt.sh), DNS resolver, HTTP response analysis.

DNS & Transport Hygiene

Metric	Value	Status
HTTPS / TLS Enforcement	—	[NOT USED]
HTTP → HTTPS Redirect	0 redirect hop(s)	[NOT CONFIGURED]
SPF Record	—	[MISSING]
DMARC Record	—	[MISSING]
DKIM Selectors Detected	None found	[NONE DETECTED]
Tech: Unknown Server	TestServer/1.0	[DETECTED]

Discovered Subdomains & CNAME Exposure

No Certificate Transparency subdomains were discovered for this target.

Detailed Audit Findings (8)

1. Missing Content Security Policy (CSP)**HIGH**

Category	Security Headers	Affected URL	http://127.0.0.1:8081/
----------	------------------	--------------	---

Description:

Content Security Policy header is not present. CSP prevents Cross-Site Scripting (XSS) and data injection attacks.

Evidence:

```
{ "header": "Content-Security-Policy", "status": "Missing", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Implement a strong Content-Security-Policy header restricting script execution and resource loading.

2. Missing X-Frame-Options Header**MEDIUM**

Category	Security Headers	Affected URL	http://127.0.0.1:8081/
----------	------------------	--------------	---

Description:

The X-Frame-Options header is absent, rendering the application potentially susceptible to Clickjacking framing attacks.

Evidence:

```
{ "header": "X-Frame-Options", "status": "Missing", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Configure 'X-Frame-Options: DENY' or 'X-Frame-Options: SAMEORIGIN' on HTTP responses.

3. Missing or Invalid X-Content-Type-Options Header**MEDIUM**

Category	Security Headers	Affected URL	http://127.0.0.1:8081/
----------	------------------	--------------	---

Description:

Missing 'X-Content-Type-Options: nosniff' header allows browsers to MIME-sniff response content types, potentially executing untrusted assets.

Evidence:

```
{ "header": "X-Content-Type-Options", "value": "Missing", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Set 'X-Content-Type-Options: nosniff' header across all responses.

4. Missing Referrer-Policy Header**LOW**

Category	Security Headers	Affected URL	http://127.0.0.1:8081/
----------	------------------	--------------	---

Description:

No Referrer-Policy header specified. Browsers may send full referrer URLs containing sensitive path parameters.

Evidence:

```
{ "header": "Referrer-Policy", "status": "Missing", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Set 'Referrer-Policy: strict-origin-when-cross-origin' or 'no-referrer'.

5. Missing Permissions-Policy Header**INFO**

Category	Security Headers	Affected URL	http://127.0.0.1:8081/
-----------------	------------------	---------------------	---

Description:

Permissions-Policy header is missing. Controlling browser features (geolocation, camera, microphone) is recommended.

Evidence:

```
{ "header": "Permissions-Policy", "status": "Missing", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Define a Permissions-Policy header to restrict access to hardware APIs.

6. Server Software Version Disclosure**INFO**

Category	Information Disclosure	Affected URL	http://127.0.0.1:8081/
-----------------	------------------------	---------------------	---

Description:

The Server header discloses precise software version numbers: 'TestServer/1.0'.

Evidence:

```
{ "header": "Server", "value": "TestServer/1.0", "owasp_link":  
"https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html" }
```

Remediation Action:

Configure web server to suppress banner version details (e.g., ServerTokens Prod in Apache, server_tokens off in Nginx).

7. Server Version Disclosed in HTTP Response Header**LOW**

Category	Information Disclosure	Affected URL	http://127.0.0.1:8081/
-----------------	------------------------	---------------------	---

Description:

The server response includes a 'Server' header that reveals specific version information: 'TestServer/1.0'. Attackers can use this to identify vulnerable software versions and target known CVEs.

Evidence:

```
{ "header": "Server", "value": "TestServer/1.0", "owasp_link":  
"https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html" }
```

Remediation Action:

Configure the web server to suppress or genericize the Server header. Nginx: 'server_tokens off;' | Apache: 'ServerTokens Prod; ServerSignature Off' | IIS: Remove via URL Rewrite or custom headers module.

8. Target Does Not Use HTTPS / TLS Encryption**HIGH****Category**

TLS / Transport Security

Affected URL<http://127.0.0.1:8081/>**Description:**

The target is served over plain HTTP with no TLS/SSL encryption. All data transmitted between clients and the server — including credentials, session tokens, and sensitive data — is exposed to passive eavesdropping and active man-in-the-middle (MITM) attacks.

Evidence:

```
{ "scheme": "http", "tls_present": false, "owasp_link":  
"https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html" }
```

Remediation Action:

Obtain a TLS certificate (e.g., free via Let's Encrypt) and configure the server to serve exclusively over HTTPS. Redirect all HTTP traffic to HTTPS using a 301 permanent redirect.
